BÁO CÁO THỰC HÀNH AN TOÀN GAME

Phân tích cơ chế kiểm tra License và chỉnh sửa ứng dụng Android

Họ và tên: Nguyễn Đăng Bá Khôi Mã sinh viên: B24DCGA078

Lớp: D24CQGA02-B

Ứng dụng thực hành: BentoLoop | Công cụ: Ghidra, công cụ giải đóng gói/đóng gói APK

1. Mục tiêu và phạm vi

Bài thực hành nhằm tìm hiểu cách một ứng dụng game Android kiểm tra License, xác định dữ liệu khóa trong chương trình, phân tích nhánh xử lý xác thực và đánh giá rủi ro khi cơ chế kiểm tra được thực hiện ở phía thiết bị. Các thao tác chỉ được thực hiện trong phạm vi ứng dụng phục vụ học tập.

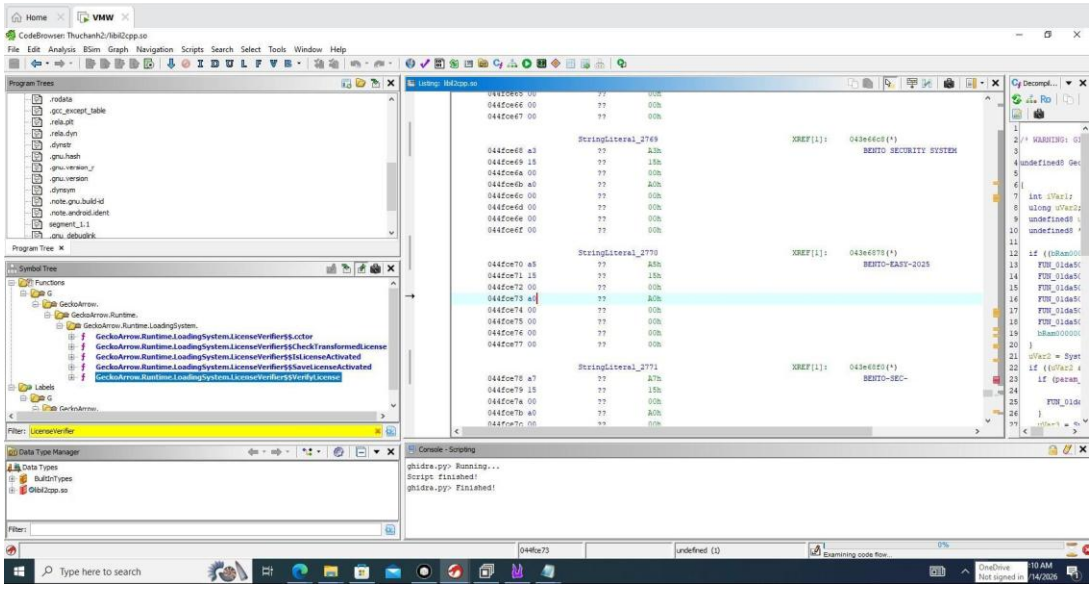
2. Quy trình thực hiện

2.1. Tìm vị trí xử lý Security và khóa License

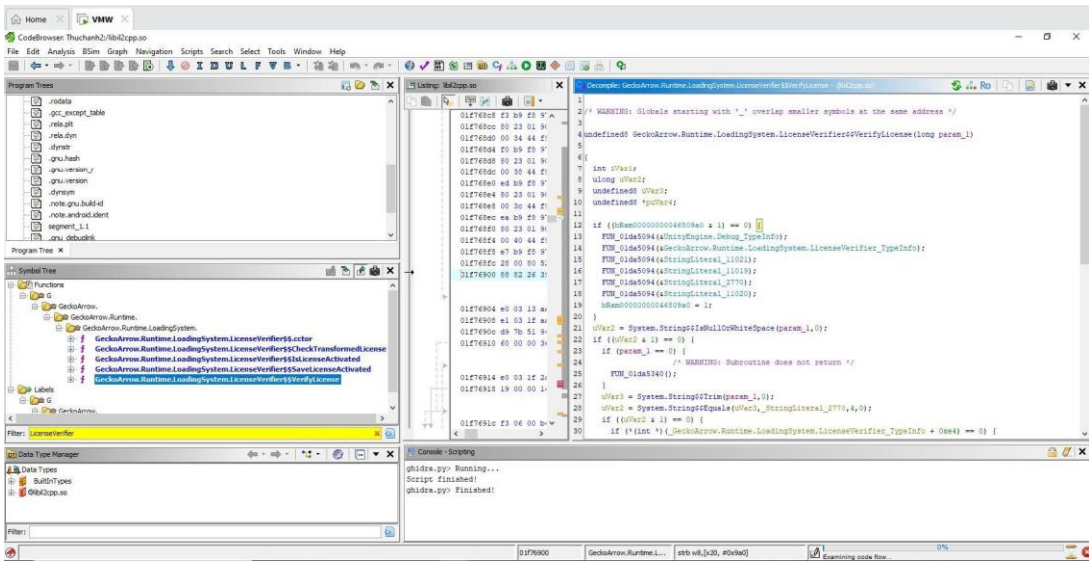
Input: Tệp thư viện của ứng dụng đã được đưa vào Ghidra để phân tích; từ khóa tìm kiếm "Security".

Thực hiện: Sử dụng bộ lọc/tìm kiếm trong Ghidra, truy cập các kết quả liên quan đến Security, lần theo vị trí mã xử lý và dữ liệu khóa được tham chiếu.

Output: Xác định được vị trí liên quan đến kiểm tra License và chuỗi khóa BENTO-EASY-2025 theo ghi chép của buổi thực hành.



Hình 1. Kết quả tìm kiếm Security trong Ghidra.



Hình 2. Truy cập vị trí mã liên quan đến khóa License.

2.2. Kiểm tra khóa trên ứng dụng

Input: Chuỗi khóa BENTO-EASY-2025 được tìm thấy khi phân tích bản gốc; sau chỉnh sửa, thử nghiệm với chuỗi bất kỳ để đánh giá cơ chế bypass all pass.

Thực hiện: Nhập khóa vào màn hình kiểm tra License của ứng dụng.

Output: Theo tài liệu gốc, khóa BENTO-EASY-2025 cho phép truy cập game. Ảnh bổ sung cho thấy nhập ký tự “a” và màn hình thông báo kích hoạt thành công, là bằng chứng thử nghiệm cơ chế bỏ qua kiểm tra License với một giá trị không phải khóa gốc.



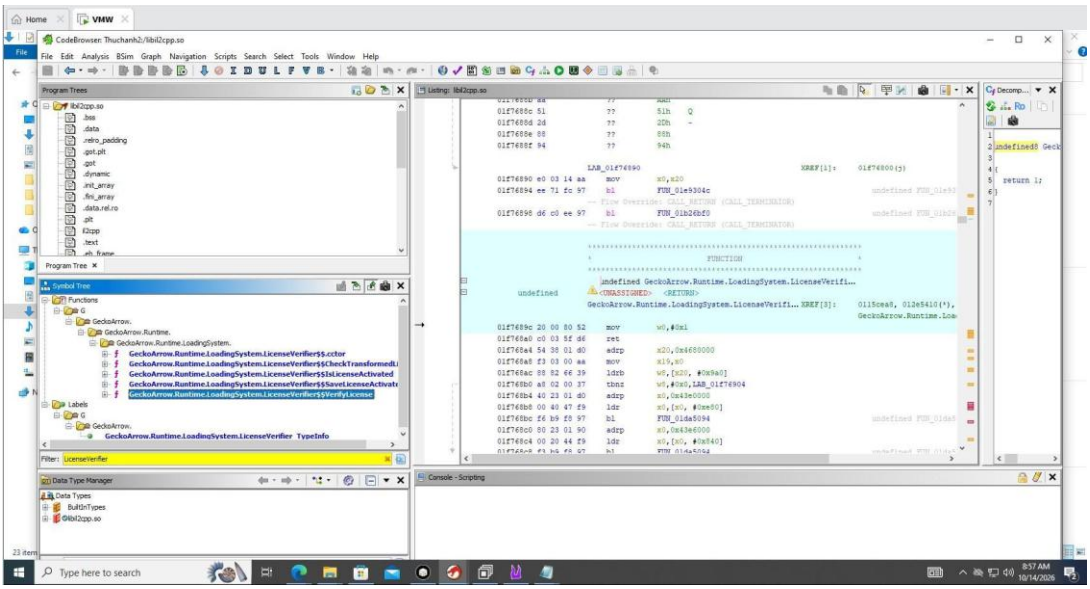
Hình 3. Màn chơi sau bước kiểm tra License.

2.3. Phân tích và chỉnh sửa LicenseVerifier

Input: Thư viện ứng dụng và kết quả tìm kiếm "LicenseVerifier" trong Ghidra.

Thực hiện: Xác định hàm kiểm tra License, quan sát các lệnh đầu hàm và chỉnh sửa luồng trả về theo nội dung thực hành để hàm trả về giá trị thành công (1), thay vì phụ thuộc vào kết quả xác thực ban đầu.

Output: Vùng mã LicenseVerifier đã được chỉnh sửa theo hướng trả về kết quả xác thực thành công. Ảnh thử nghiệm bổ sung ghi nhận một chuỗi khác khóa gốc được chấp nhận; chưa đủ để khẳng định đã kiểm thử mọi chuỗi có thể nhập.

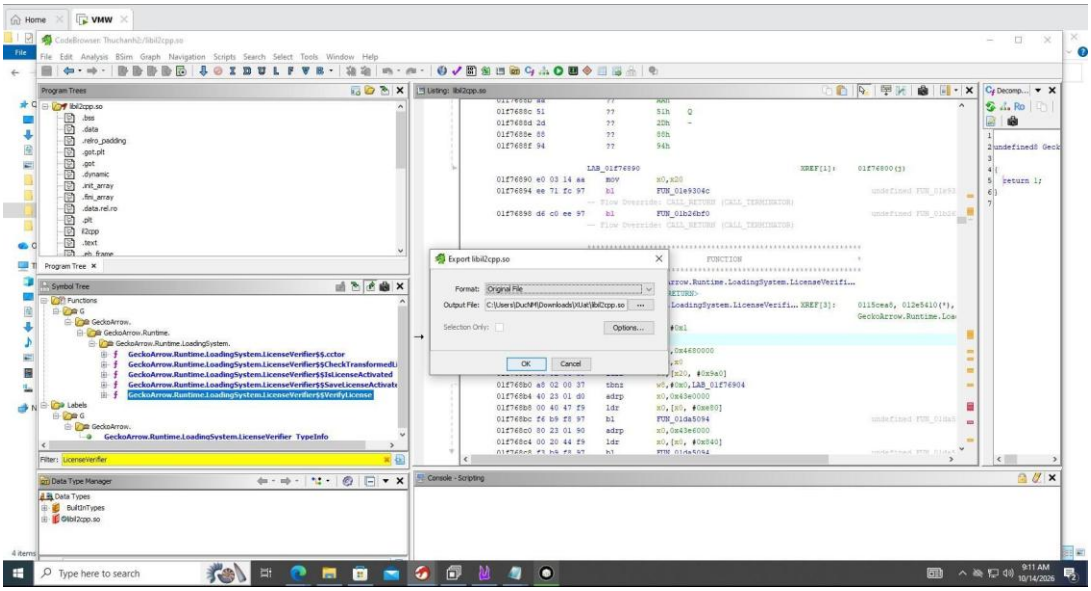


Hình 4. Vị trí LicenseVerifier và vùng lệnh được chỉnh sửa.

2.4. Xuất thư viện và thay vào APK

Input: Thư viện đã chỉnh sửa trong Ghidra và bản APK được giải đóng gói.

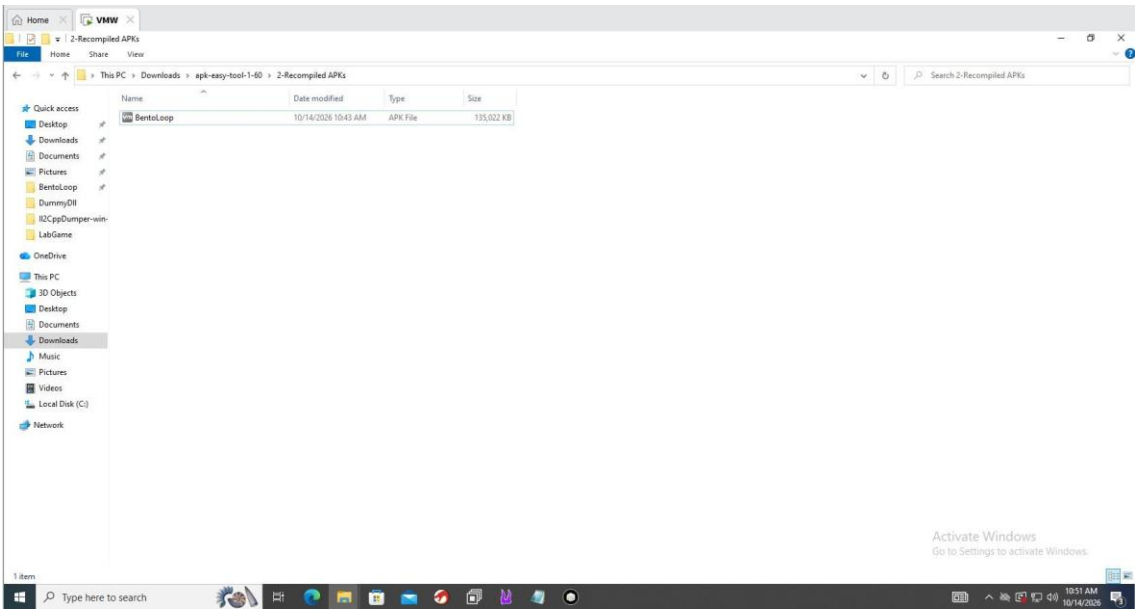
Thực hiện: Sử dụng chức năng Export Program và lựa chọn định dạng Original File theo ghi chú trong tài liệu; sau đó chuẩn bị thay thế tệp thư viện tương ứng trong cấu trúc APK.



Hình 5. Hộp thoại xuất thư viện từ Ghidra.

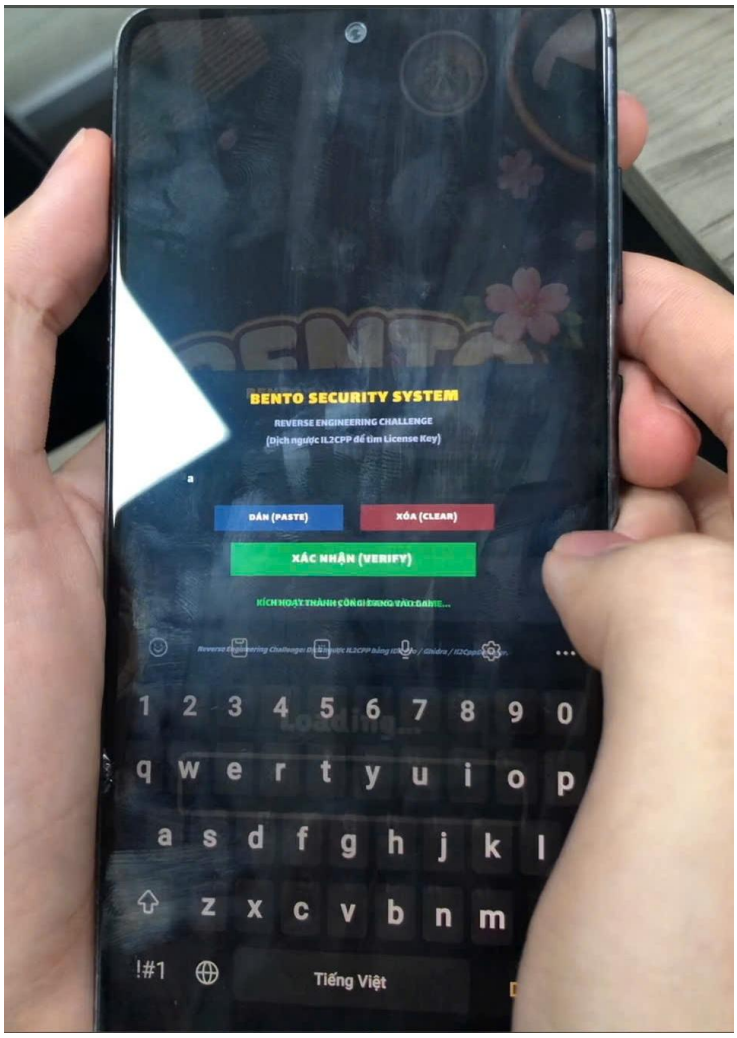
3. Compile APK và kiểm tra bypass all pass

Hình 6 ghi nhận tệp BentoLoop.apk trong thư mục “2-Recompiled APKs” của APK Easy Tool, loại APK File, kích thước 135.022 KB. Đây là đầu ra của bước đóng gói lại APK..



Hình 6. Tệp APK được tạo sau khi compile bằng APK Easy Tool.

Hình 7 chụp giao diện BENTO SECURITY SYSTEM trên điện thoại. Ô nhập đang hiển thị ký tự "a" và dòng trạng thái màu xanh "KÍCH HOẠT THÀNH CÔNG! ĐANG VÀO GAME...". Kết quả này cho thấy việc xác thực thành công với một giá trị khác khóa gốc, phù hợp với mục tiêu chỉnh sửa LicenseVerifier để bỏ qua điều kiện kiểm tra (bypass all pass).



Hình 7. Thử nghiệm xác thực bằng chuỗi khác khóa gốc trên thiết bị.

Đánh giá: Hai ảnh bổ sung chứng minh có tệp APK được biên dịch lại và có thử nghiệm xác thực thành công trên thiết bị.

Link apk đã fix: https://drive.google.com/file/d/1ICiCLlThQEWY-s_a3Q_ns1Pj3j1_Gedd/view?usp=sharing

4. Đề xuất biện pháp phòng tránh

Không lưu khóa License cố định dưới dạng chuỗi dễ truy vết trong thư viện ứng dụng. Thực hiện xác thực quyền sử dụng trên máy chủ, có cơ chế cấp phiên và giới hạn thời gian hiệu lực. Kết hợp kiểm tra tính toàn vẹn của ứng dụng, chữ ký gói cài đặt và phát hiện môi trường bị can thiệp; không coi các kiểm tra phía client là lớp bảo vệ duy nhất. Với các quyết định quan trọng như mở khóa nội dung, máy chủ cần xác minh trạng thái cấp phép độc lập. Bổ sung giám sát bất thường và quy trình kiểm thử an toàn trước phát hành.